CASE STUDY

Plex Media Server, CVE-2026-96652, CVE-2026-96654, CVE-2026-96655 and CVE-2026-96656: The Plex2Shell Chain in the Lab

A TeamStarWolf case study. Published 4 November 2026; every source checked as of that date.

Executive summary

If you run Plex Media Server for yourself, your family or your friends, and you ever turned on Remote Access or forwarded port 32400, this study is about your server. Four flaws in Plex Media Server before 1.43.3.10861, each rated Medium or High on its own, chain into code execution by an unauthenticated remote attacker with the privileges of the server process (**Confirmed**: Plex) [9]. The researcher who found them, Zach Main, calls the chain Plex2Shell and rates it 9.8 Critical [12]. Plex shipped the fixed build on 4 August 2026 [10]. The details went public on 16 October 2026, attacks on a honeypot began the next morning [14], and by 19 October Plex was describing the flaws as actively and widely exploited, with compromised servers running cryptocurrency miners and proxy software [9]. CISA added all four to the Known Exploited Vulnerabilities catalog on 20 October 2026 [7].

This study is lab-backed, and the lab run was deliberately narrow. On 4 November 2026 UTC a lab host ran official `plexinc/pms-docker` images in matched pairs, a vulnerable build beside the fixed 1.43.3.10861, on loopback only. No exploit step ran: no request reached any endpoint in the chain [38] [39] [40] [41]. What the lab shows is how to find a vulnerable server and prove the fix, and it turned up three practical traps. A host package check returned nothing while two Plex servers ran in containers. A naive version parser read the XML declaration's `version="1.0"` and labelled the fixed build vulnerable. And the vendor's own advisory title can make 1.43.3.10828, the last vulnerable build, look safe (**Demonstrated** for the first two; **Inferred** for the third) [38] [39] [9].

> Evidence grade: the four vulnerabilities, the fixed build and the KEV listing are **Confirmed**; the chain mechanics are **Confirmed** from the researcher's own write-up; press coverage of the attacks is **Reported**; the lab's version checks, baselines and fix verification are **Demonstrated**.

Key facts at a glance

Field	Value
Product	Plex Media Server (PMS) on Windows, macOS, Linux, NAS, Docker and NVIDIA Shield, the platforms the vendor's update steps cover; the official Docker image is `plexinc/pms-docker` [5] [9] [22]
Identifiers	CVE-2026-96652, CVE-2026-96654, CVE-2026-96655 and CVE-2026-96656; GitHub advisories GHSA-5p7w-r379-3c2m, GHSA-3j7c-jr86-m5jq, GHSA-9x88-w2p7-56vh and GHSA-2g2v-9wf5-6m3g [5] [8]
Researcher name	Plex2Shell (Zach Main, credited in every CVE record) [5] [12]
Weaknesses	CWE-918 (-96652, -96655), CWE-84 (-96654), CWE-73 (-96656) [1] [2] [3] [4]
Scores	Individually CVSS 3.1 4.3, 6.5, 4.3 and 7.2 (CISA as CNA); the researcher rates the full chain 9.8 Critical, PR:N [1] [2] [3] [4] [12]
Affected	Every build before 1.43.3.10861, including 1.43.3.10828 [5] [6] [9]
Fixed	1.43.3.10861, general release 4 August 2026 (Beta 3 August) [10] [6]
Disclosure	Reported to Plex 27 July 2026; CVEs published 23 September 2026; write-up public 16 October 2026 [12] [5]
Exploitation	First seen on a honeypot 17 October 2026; vendor reports wide exploitation; in CISA KEV since 20 October 2026 [14] [9] [7]
Payloads seen	Cryptocurrency miners and proxyware (`mylovelyminer`, `x12345`, `myawesomeproxy`); no named group, ransomware use Unknown [9] [7]
KEV due dates	23 October 2026 (-96654, -96656) and 3 November 2026 (-96652, -96655); forensic triage flagged for -96656 [7]
Lab result	Version exposure and fix verified on 1.43.2.10687 and 1.43.3.10828 against 1.43.3.10861; no exploit step run (**Demonstrated**) [38] [39] [40] [41]
Workaround	Turn off Remote Access if you do not need it; do not forward 32400 directly [9]

Key findings

- **Four modest bugs make one critical chain.** On their own the four CVEs score Medium or High, and three carry a privilege requirement in their vectors (Low for -96652 and -96655, High for -96656), although -96652's record says any token value is accepted. Chained, they need nothing: a timeline request that checks only that a token header exists, a loopback-only plugin API with a broken input guard, an owner-token leak through a prefix match on `http://127.0.0.1`, and a transcoder option that writes a shared object into the Codecs folder, which the transcoder then loads (**Confirmed**: researcher) [12].

- **The fix was out for ten weeks before the details.** 1.43.3.10861 reached general release on 4 August 2026, the day Plex acknowledged the report [10] [12]. Plex announced the security update on 1 September and the CVEs followed on 23 September [9] [5]. Exploitation followed the public write-up of 16 October by about a day [14].
- **The version line is 1.43.3.10861, not 1.43.3.** The vendor's advisory title says "v1.43.2 and earlier" and its first post asks for "1.43.3 or newer" [9]. Every CVE record, the CISA advisory and Plex's own October update put the fixed line at 1.43.3.10861, so 1.43.3.10828 is vulnerable (**Inferred** from the Confirmed records) [5] [6] [9]. NVD's "Release Notes" reference points at the 1.43.3.10828 release post, which lists no security fixes [10].
- **The primaries disagree on which CVE is which step.** Plex's CVE table maps CVE-2026-96655 to disclosure of the owner's admin token. NVD, the CISA advisory and KEV describe it as an authenticated SSRF in `/video/:/transcode/universal`. The proof-of-concept README maps it differently again (**Confirmed** disagreement) [9] [3] [6] [7] [13]. This study uses the CVE record wording, because CISA is the CNA.
- **The lab found the blind spot in a package check.** On a Docker-only host, `dpkg-query` and `rpm -q` reported no Plex package while two Plex servers were listening (**Demonstrated**) [38].
- **The lab found the trap in a version parser.** A check that grepped every `version="..."` attribute from `/identity` picked up the XML declaration, `version="1.0"`, and labelled the fixed 1.43.3.10861 build vulnerable. The corrected parse reads only the MediaContainer attribute (**Demonstrated**) [38] [39].
- **Patching is not the end state for an exposed server.** KEV flags CVE-2026-96656 for forensic triage, and Plex says any internet-reachable server older than 1.43.3.10861 should be assumed possibly compromised [7] [9].

Top recommendations

1. Update every Plex Media Server to 1.43.3.10861 or later, and check the full build number, not just "1.43.3" [9] [5].
2. Inventory Plex in containers as well as packages: look for `plexinc/pms-docker` images and tags, not just `plexmediaserver` packages (**Demonstrated** gap) [38].
3. If a server older than 1.43.3.10861 was reachable from the internet, treat it as possibly compromised: rebuild from a clean install, empty the Codecs folder, check the transcoder options in the server preferences, sign out all devices and change the Plex password [9].
4. Turn off Remote Access where you do not need it and stop forwarding port 32400 directly [9].
5. Hunt for the vendor's indicators: processes named `myawesomeproxy`, `mylovelyminer` or `x12345` started by Plex, unfamiliar `.so` or `.dll` files in Codecs, outbound connections to `proxystream.st`, and high CPU while nothing plays [9].

Scope and method

This study covers the four Plex Media Server CVEs that CISA lists as chainable, from the private report on 27 July 2026 to the lab run on 4 November 2026 UTC. A fifth bug fixed in the same build, CVE-2026-96651, is noted but is not part of the chain [6]. Every source in the Sources table was opened on 4 November 2026. The public proof-of-concept repository is recorded by name and metadata only; its code was not opened, copied or run [13].

Grade	Meaning
Confirmed	A primary source was opened: the CVE record, NVD, CISA, the vendor, the researcher's own write-up, or a first-hand observation by the person who made it
Reported	A secondary source's account, not independently corroborated (press coverage)
Demonstrated	Shown in this study's lab run; the capture file is named
Inferred	The study's reasoning from the record and the lab, labelled where it appears

Exploit-class steps are described in one sentence and never quoted or shown. The lab ran none. Version checks, baselines and the observables that differ between the vulnerable and fixed builds are quoted from the captures.

Part 1: the four flaws

What each CVE is

Each record lists Plex Media Server as affected below 1.43.3.10861 and unaffected at 1.43.3.10861 [5]. CISA assigned all four as the CNA, and NVD shows the CNA scores as Secondary (**Confirmed**) [1] [2] [3] [4] [5].

CVE	Weakness	What the record says	CVSS 3.1	CVSS 4.0	Privileges in the vector
CVE-2026-96652	CWE-918 Server-Side Request Forgery	SSRF via `/player/timeline`: any `X-Plex-Token` value is accepted, and a full URL in the `protocol` parameter makes the server POST to a destination the attacker picks	4.3 Medium	5.3 Medium	Low
CVE-2026-96654	CWE-84 Improper Neutralization of Encoded URI Schemes in a Web Page	URL values in `searchOne` are not neutralized, so an attacker can call other plugins' functions with their own parameters	6.5 Medium	6.9 Medium	None
CVE-2026-96655	CWE-918 Server-Side Request Forgery	An authenticated user can make the server request arbitrary internal or external addresses through the `/video/:/transcode/universal` path parameter	4.3 Medium	5.3 Medium	Low

CVE	Weakness	What the record says	CVSS 3.1	CVSS 4.0	Privileges in the vector
CVE-2026-96656	CWE-73 External Control of File Name or Path	An admin can write arbitrary files that may run on load: `TranscoderH264Options` is appended verbatim to x264's option string, and at startup every `.so` file is loaded with no signature, execute-bit or symbol check	7.2 High	8.6 High	High

Sources: [1] [2] [3] [4]. The full CVSS 3.1 vectors are `AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N` for -96652 and -96655, `AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N` for -96654 and `AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H` for -96656 [1] [2] [3] [4].

The CVE-2026-96652 vector says Low privileges while its description says any token value is accepted. Both are in the record; the researcher's account explains the gap: the endpoint checks that a token header is present, not that it is valid [1] [12].

How the four chain

The researcher's write-up of 16 October 2026 describes five stages (**Confirmed**: researcher) [12]:

1. **A forged request from the server.** The timeline endpoint checks only that a token header exists, and a full URL in its `protocol` parameter makes the server POST to a destination the attacker picks [1] [12]. In the chain, that destination is the server's own loopback interface.
2. **A loopback-only API that trusts loopback.** The `/system/agents/*` API opens without a token on loopback. The identifier guard in `searchOne` is dead code, and the identifier is spliced unencoded into an internal URL, which lets a forged call reach another plugin's function.
3. **An owner-token leak.** The plugin framework attaches the server owner's token to any URL that merely starts with `http://127.0.0.1`. A lookalike hostname that begins that way but resolves elsewhere (the write-up names `sslip.io` names) receives the token.
4. **A file write into Codecs.** With the owner token, the attacker sets the transcoder's x264 options so that the transcoder writes a file into the Codecs folder. The transcoder fetches the media from a remote host with no host allowlist.
5. **An unsigned load.** The transcoder loads the `.so` from the Codecs folder with no signature check, and the code runs as the `plex` user.

The researcher rates the full chain CVSS 3.1 9.8 Critical (`PR:N`) [12]. No CVSS record scores the chain itself. Plex's October update says the same thing in plain terms: chained, the issues let an unauthenticated remote attacker run code with the privileges of the server process (**Confirmed**: Plex) [9].

The researcher says large language models were used heavily in a recon, hunt, verify and chain workflow, and that the judgement calls on what to look for and what to prioritize were the researcher's own (**Confirmed** as the researcher's account of their own method) [12].

The fifth bug in the same build

The CISA advisory VA-26-266-01 lists five Plex CVEs fixed in 1.43.3.10861. The fifth, CVE-2026-96651, is a path traversal (CWE-22) through `/system/agents/media/get`, CVSS 3.1 6.5. It is not in KEV and is not part of the Plex2Shell chain (**Confirmed**) [6] [7].

Part 2: the public record

Timeline

Date	Event	Source	Grade
2026-05-19	Docker tag `1.43.2.10687-563d026ea` pushed (a vulnerable build used in the lab)	[11]	Confirmed
2026-07-14	1.43.3.10828 general release, the last vulnerable 1.43.3 build; its notes list no security fixes; Docker tag pushed the same day	[10] [11]	Confirmed
2026-07-27	Zach Main reports the chain to Plex	[12]	Confirmed
2026-08-03	1.43.3.10861 Beta; the CISA advisory gives this as each CVE's release date	[10] [6]	Confirmed
2026-08-04	1.43.3.10861 general release and Docker tag; Plex acknowledges the report and pays a bounty	[10] [11] [12]	Confirmed
2026-09-01	Plex announces the security update, asks owners to update to "1.43.3 or newer", and says CVEs have been requested	[9]	Confirmed
2026-09-23	CISA, as CNA, reserves and publishes the four CVEs; CISA advisory VA-26-266-01; NVD and GitHub advisories published	[5] [6] [1] [8]	Confirmed
2026-10-16	The researcher's Plex2Shell write-up goes public; Plex dates the public PoC to the same day	[12] [9]	Confirmed
2026-10-17	A honeypot operator sees the first in-the-wild exploitation, that morning	[14]	Confirmed (first-hand, one honeypot)
2026-10-18	The PoC repository `code-zm/plex2shell` is created on GitHub	[13]	Confirmed
2026-10-19	Plex's update: CVE details, the chain, active and wide exploitation, miners and proxy software, IOCs; CISA's SSVC entry for -96656 moves to exploitation active	[9] [4]	Confirmed
2026-10-19	SecurityWeek and The Hacker News report the attacks	[15] [17]	Reported
2026-10-20	CISA adds all four to KEV; SSVC moves to exploitation active for -96652, -96654 and -96655	[7] [1] [2] [3]	Confirmed
2026-10-21	BleepingComputer reports CISA's warning	[16]	Reported
2026-10-23	KEV due date for -96654 and -96656	[7]	Confirmed
2026-11-03	KEV due date for -96652 and -96655	[7]	Confirmed
2026-11-04	This study's lab run (UTC)	[38] [39] [40] [41]	Demonstrated

Three dates that disagree

- **The PoC date.** Plex and SecurityWeek put the write-up and the PoC on 16 October [9] [15]. BleepingComputer says the PoC followed the write-up by three days [16]. The repository that hosts it now was created on 18 October [13]. The defensible statement is that the write-up went public on 16 October, Plex dates the public PoC to the same day, and the current repository dates from 18 October (**Inferred** from the Confirmed dates).
- **The fix date.** The Hacker News dates the fix to 3 August, the Beta [17]; BleepingComputer to 4 August, the general release [16]. The vendor's release thread supports both [10].
- **The CVE release date.** The CISA advisory gives 3 August as each CVE's release date, while the CVE records were reserved and published on 23 September [6] [5].

Which CVE is which step

The primaries disagree, and a defender reading only one of them will mislabel at least one step (**Confirmed** disagreement) [9] [1] [2] [3] [4] [6] [7] [13]:

CVE	NVD, CISA advisory and KEV	Plex's CVE table (19 October)	PoC README
CVE-2026-96652	SSRF via `/player/timeline`	Unauthenticated timeline SSRF	Not recorded here
CVE-2026-96654	`searchOne` URL values not neutralized	Access to internal agent functions over loopback	Not recorded here
CVE-2026-96655	Authenticated SSRF via `/video/:/transcode/universal`	Disclosure of the server owner's admin token	Owner-authenticated transcoder SSRF plus file write
CVE-2026-96656	Admin file write; unsigned `.so` load	Arbitrary file write to Codecs through transcoder preferences	Not recorded here

In the researcher's own write-up, the token theft comes out of the `searchOne` pivot (stage 3) [12]. This study uses the CVE record wording for each id.

The version trap

The advisory's title is "Important Security Update for Plex Media Server v1.43.2 and earlier", and its first post, on 1 September, asks owners to update to "1.43.3 or newer" [9]. Read alone, both suggest 1.43.3.10828 is safe. It is not: every CVE record, the CISA advisory and Plex's own update of 19 October put the fixed line at 1.43.3.10861 (**Inferred** from the Confirmed records) [5] [6] [9]. NVD adds to the confusion. Its "Release Notes" reference is the release post for 1.43.3.10828 of 14 July, the last vulnerable 1.43.3 build, not the fixed one [10]. The fixed build's notes carry two security lines that 1.43.3.10828 lacks: PM-5763, a potential CompanionProxy vulnerability, and PM-5766, which stops `TranscoderH264Options` and `TranscoderH264OptionsOverride` being changed over the network (**Confirmed**) [10].

Scores and ratings

All CVSS scores are CISA's as CNA [1] [2] [3] [4]. CISA's advisory carries a risk note: in the worst case, a remote attacker could steal account credentials and then write files or run code [6]. CISA's SSVC entries in the NVD records moved exploitation from none to active on 20 October 2026, and on 19 October for CVE-2026-96656 [1] [2] [3] [4]. The GitHub advisories mirror the NVD severities: medium for -96652, -96654 and -96655, high for -96656 [8].

Part 3: exploitation in the wild

- **The first sighting.** An independent honeypot operator first saw Plex2Shell exploitation on the morning of 17 October 2026, from `45.194.92.222`, with further attempts from `91.92.40.202` and `176.65.139.228` (**Confirmed** as the operator's first-hand observation) [14]. Two files, `docker` (which the operator says contained a cryptominer) and a UPX-packed binary named `x`, were downloaded from `217.60.194.116`; a later update that day added an XMRig sample and the proxy tool `myawesomeproxy` [14]. The operator reports a `Python-urllib/3.10` user agent and `sslip.io` callback hostnames, and has published packet captures from their own lab test of the chain, for signature work, at `github.com/BoredHackerBlog/plex2shell_pcap`, which was not opened for this study [14]. These indicators cover one honeypot only, and the operator notes it [14].
- **The vendor's account.** Plex says the flaws have been actively and widely exploited since the public PoC, in attacks on unpatched internet-facing servers, and that compromised servers ran cryptocurrency miners and proxy software that routes other people's traffic through the victim's connection (**Confirmed**: Plex) [9].
- **CISA.** All four CVEs entered KEV on 20 October 2026, each marked as chainable with the other three. Known ransomware use is Unknown. Only CVE-2026-96656 is flagged for forensic triage. The required action cites Binding Operational Directive 26-04 (**Confirmed**) [7].
- **The press.** SecurityWeek reports that exploitation began one day after the write-up and PoC, with an XMRig-based miner and `myawesomeproxy` dropped, and notes that Plex shipped the fixes before announcing them (**Reported**) [15]. The Hacker News reports a shell script fetching the miner `x12345` and a miner process `mylovelyminer` pointing at a `proxystream.st` host. It cites Bitsight as linking `proxystream.st` infrastructure to the AISURU DDoS and proxyware botnet, and Reddit users reporting the same miner with the cause unconfirmed (**Reported**) [17]. BleepingComputer covers CISA's warning (**Reported**) [16].
- **Who.** No source opened attributes the exploitation to a named group, KEV marks ransomware use as Unknown, and every observed payload is a cryptominer or proxyware (**Inferred** from the sources opened) [7] [9] [14].

Part 4: what the lab showed

The lab ran on a Linux lab host with Docker on 4 November 2026 UTC, with every published port bound to `127.0.0.1`, every server left unclaimed (no Plex account sign-in), and every container removed afterwards [38] [39] [40] [41]. The four CVE runs used two pairs of images. The CVE-2026-96652 run set 1.43.2.10687 against the fixed 1.43.3.10861; the other three set 1.43.3.10828, the last vulnerable 1.43.3 build, against 1.43.3.10861. The screenshots are renderings of the captured terminal output with a neutral `lab$` prompt and the lab host anonymized.

Setup: matched pairs on loopback

The CVE-2026-96652 run pulled `plexinc/pms-docker:1.43.2.10687-563d026ea` (digest `sha256:c37106c5...`) and `plexinc/pms-docker:1.43.3.10861-07dfddaeb` (digest `sha256:5bc1d13f...`), created a named volume for each, and ran the vulnerable server on `127.0.0.1:32400` and the fixed one on `127.0.0.1:32401` (**Demonstrated**, CVE-2026-96652/01-setup.txt). Both reported `(healthy)` in `docker ps` (**Demonstrated**, CVE-2026-96652/02-test.txt). The other runs pulled `1.43.3.10828-00f62d37d` (digest `sha256:a2b03d75...`) in place of 1.43.2.10687 [39] [40] [41]. All three digests match the Docker Hub tag records [11].

CVE-2026-96652 setup

```
lab$  docker pull plexinc/pms-docker:1.43.2.10687-563d026ea
1.43.2.10687-563d026ea: Pulling from plexinc/pms-docker
2f7571f14c6f: Pulling fs layer
e8e822b367b1: Pulling fs layer
9053cb34b9b6: Pulling fs layer
58fc5b7e141e: Pulling fs layer
1743c70a1668: Pulling fs layer
25ccef660e4a: Pulling fs layer
2f7571f14c6f: Waiting
e8e822b367b1: Waiting
9053cb34b9b6: Waiting
58fc5b7e141e: Waiting
1743c70a1668: Waiting
25ccef660e4a: Waiting
2f7571f14c6f: Verifying Checksum
2f7571f14c6f: Download complete
e8e822b367b1: Verifying Checksum
e8e822b367b1: Download complete
2f7571f14c6f: Pull complete
e8e822b367b1: Pull complete
9053cb34b9b6: Verifying Checksum
9053cb34b9b6: Download complete
9053cb34b9b6: Pull complete
58fc5b7e141e: Verifying Checksum
58fc5b7e141e: Download complete
58fc5b7e141e: Pull complete
1743c70a1668: Verifying Checksum
1743c70a1668: Download complete
1743c70a1668: Pull complete
25ccef660e4a: Verifying Checksum
25ccef660e4a: Download complete
25ccef660e4a: Pull complete
Digest: sha256:c37106c57fed7a6624f5dee5a3ce460ff011f09a2aa7f4ee9e8dbbd08ae1b87e
Status: Downloaded newer image for plexinc/pms-docker:1.43.2.10687-563d026ea
docker.io/plexinc/pms-docker:1.43.2.10687-563d026ea

lab$  docker pull plexinc/pms-docker:1.43.3.10861-07dfddaeb
1.43.3.10861-07dfddaeb: Pulling from plexinc/pms-docker
39a120c374bd: Pulling fs layer
47ac83ae0904: Pulling fs layer
9eed30a07047: Pulling fs layer
58fc5b7e141e: Pulling fs layer
982db2db2146: Pulling fs layer
884493278fd6: Pulling fs layer
9eed30a07047: Waiting
58fc5b7e141e: Waiting
982db2db2146: Waiting
884493278fd6: Waiting
47ac83ae0904: Verifying Checksum
47ac83ae0904: Download complete
9eed30a07047: Verifying Checksum
9eed30a07047: Download complete
39a120c374bd: Verifying Checksum
39a120c374bd: Download complete
58fc5b7e141e: Verifying Checksum
58fc5b7e141e: Download complete
982db2db2146: Verifying Checksum
982db2db2146: Download complete
39a120c374bd: Pull complete
47ac83ae0904: Pull complete
9eed30a07047: Pull complete
58fc5b7e141e: Pull complete
982db2db2146: Pull complete
884493278fd6: Verifying Checksum
884493278fd6: Pull complete
Digest: sha256:5bc1d13f48da6366f46aaf2a3ce1a6292897eadc1f8efcbbd7321d30e94f2ed4
Status: Downloaded newer image for plexinc/pms-docker:1.43.3.10861-07dfddaeb
docker.io/plexinc/pms-docker:1.43.3.10861-07dfddaeb

lab$  docker volume create plexlab-vuln-config && docker volume create plexlab-fixed-config
plexlab-vuln-config
plexlab-fixed-config

lab$  docker run -d --name plexlab-vuln -e TZ=UTC -v plexlab-vuln-config:/config -p 127.0.0.1:32400:32400/tcp plexin
42e1237f9f64eaae54619e3cbf39a4bc584462ec2dcde1822f08f5c55cd75e36

lab$  docker run -d --name plexlab-fixed -e TZ=UTC -v plexlab-fixed-config:/config -p 127.0.0.1:32401:32400/tcp plex
914e901d5c8aef0aacfbf8af8b5e38b0468bb9b786100ae1b012959967abd2d5

lab$  for p in 32400 32401; do n=0; until curl -s -o /dev/null http://127.0.0.1:$p/identity; do sleep 3; n=$((n+1));
port 32400 up
port 32401 up
```

The CVE-2026-96654 and CVE-2026-96655 runs ran at the same time and first collided on the container names `plex-vuln` and `plex-fixed`. Each removed only its own container, by id, and re-ran setup from scratch (**Demonstrated**, CVE-2026-96654/01-setup-attempt1.txt and CVE-2026-96655/01-setup-attempt1-collision.txt).

The version check

An unauthenticated `GET /identity` on each unclaimed server returned a MediaContainer carrying the build number (**Demonstrated**, CVE-2026-96652/02-test.txt):

```
lab$ curl -s http://127.0.0.1:32400/identity
<MediaContainer size="0" apiVersion="1.2.2" claimed="0" ... version="1.43.2.10687-563d026ea">
lab$ curl -s http://127.0.0.1:32401/identity
<MediaContainer size="0" apiVersion="1.2.2" claimed="0" ... version="1.43.3.10861-07dfddaeb">
```

The `machineIdentifier` and `startState` attributes and the XML declaration line are cut from the quote. The package inside each container agreed (**Demonstrated**, CVE-2026-96652/02-test.txt):

```
plexmediaserver 1.43.2.10687-563d026ea
plexmediaserver 1.43.3.10861-07dfddaeb
```

The other three runs showed the same agreement for 1.43.3.10828-00f62d37d against 1.43.3.10861-07dfddaeb, through `/identity` and `dpkg-query` (**Demonstrated**, CVE-2026-96654/02-test.txt, CVE-2026-96655/02-test.txt, CVE-2026-96656/02-test.txt). A gate that compares the package version gave the right answer on the first try (**Demonstrated**, CVE-2026-96656/02-test.txt; the same result is in CVE-2026-96655/02-test.txt):

```
plex-vuln 1.43.3.10828 VULNERABLE (< 1.43.3.10861)
plex-fixed 1.43.3.10861 FIXED
```

The server log carries the version too. `docker logs` showed only `Starting Plex Media Server.`, but the server's own `Plex Media Server.log` opens with a banner such as `Plex Media Server v1.43.3.10828-00f62d37d - Docker Docker Container x86_64`, and the same line for v1.43.3.10861-07dfddaeb (**Demonstrated**: the docker logs line in CVE-2026-96656/02-test.txt; the banner in CVE-2026-96655/02-test.txt).

The test step, described

No exploit step ran in any of the four runs: no request went to `/player/timeline`, `/system/agents/*`, `/:/prefs` or `/video/:/transcode/universal`, and the test arrays in every `plan.json` hold only version, file and preference checks (**Demonstrated**) [38] [39] [40] [41]. The lab evidence is version exposure plus a file and preference baseline, not a reproduction of the chain.

What differed

Observable	Vulnerable build	Fixed build 1.43.3.10861	Capture
`/identity` MediaContainer `version` (no token, unclaimed)	`1.43.2.10687-563d026ea` or `1.43.3.10828-00f62d37d`	`1.43.3.10861-07dfddaeb`	CVE-2026-96652/02-test.txt, CVE-2026-96654/02-test.txt
`dpkg-query -W plexmediaserver` in the container	same as above	`1.43.3.10861-07dfddaeb`	CVE-2026-96652/02-test.txt, CVE-2026-96656/02-test.txt
`Plex Media Server.log` banner	`v1.43.3.10828-00f62d37d`	`v1.43.3.10861-07dfddaeb`	CVE-2026-96655/02-test.txt
Package-based gate	`VULNERABLE (< 1.43.3.10861)`	`FIXED`	CVE-2026-96656/02-test.txt
`.so` or `.dll` files in Codecs on a fresh server	`0`	no `.so` files (the listing searched `.so` only)	CVE-2026-96654/02-test.txt, CVE-2026-96655/04-mitigation.txt
`TranscoderH264Options` in `Preferences.xml`	`no-TranscoderH264Options`, `TranscoderH264Options not set`	`TranscoderH264Options not set`	CVE-2026-96654/02-test.txt, CVE-2026-96656/02-test.txt, CVE-2026-96656/04-mitigation.txt

(**Demonstrated** throughout.) Only the version differs. The empty Codecs folder and the unset transcoder option are the same on both builds, which makes them a clean baseline for file-integrity monitoring: on a fresh server, anything that appears in either place later is a change to explain [39] [41].

What the server log records about each request

`Plex Media Server.log` records every request with its source address and a locality class (**Demonstrated**, CVE-2026-96652/02-test.txt):

```
DEBUG - Request: [172.17.0.1:40438 (Subnet)] GET /identity (6 live) #60
DEBUG - Request: [[::1]:49048 (Loopback)] GET /identity (7 live) #62
```

The first is the `curl` from the lab host, arriving through the Docker bridge; the second came from inside the container. The pms-docker README confirms that with bridge networking, traffic from the host appears to Plex as coming from the Docker gateway [22]. This matters for detection in Part 6: the chain's second stage depends on requests the server sees as loopback, and the log labels loopback requests, so those requests should be visible (**Inferred**; no chain traffic was sent in the lab).

What contradicted the plan

The version parser read the XML declaration. The CVE-2026-96652 plan's verdict loop extracted every `version="..."` attribute from `/identity`. The response also carries the XML declaration, `version="1.0"`, so the loop labelled the fixed 1.43.3.10861 build as below the threshold. The run logged a DEVIATION and re-ran the loop keeping only the last match, which is the MediaContainer attribute (**Demonstrated**, CVE-2026-96652/02-test.txt):

```
127.0.0.1:32400 1.43.2.10687-563d026ea VULNERABLE (below 1.43.3.10861)
127.0.0.1:32401 1.43.3.10861-07dfddaeb FIXED
```

The same defect made the first mitigation check report the fixed build as not patched, before the corrected run printed `fixed container reports 1.43.3.10861-07dfddaeb: at or above 1.43.3.10861 (patched)` (**Demonstrated**, CVE-2026-96652/04-mitigation.txt). The CVE-2026-96654 run used a loop with the same defect and was not re-run, so its verdict line is wrong for the fixed build and is not used in this study; the `dpkg-query` cross-check is the reliable observable in that capture (**Demonstrated**, CVE-2026-96654/02-test.txt).

The version was not in the container log. The CVE-2026-96656 plan expected the server version in `docker logs`. It showed only `Starting Plex Media Server.`; the banner is in `Plex Media Server.log` (**Demonstrated**: CVE-2026-96656/02-test.txt for the docker logs line; CVE-2026-96655/02-test.txt for the banner).

The exposure check on the lab host

The exposure checks ran on the lab host itself (**Demonstrated**, CVE-2026-96652/03-exposure.txt). `ss -ltn` showed only `127.0.0.1:32400` and `127.0.0.1:32401` listening. The host's `dpkg-query -W plexmediaserver` reported `no packages found matching plexmediaserver`, and `rpm -q plexmediaserver` reported `package plexmediaserver is not installed`, while `docker ps` listed both Plex images. A host package check alone misses a containerized server (the outputs **Demonstrated**; the conclusion **Inferred**).

CVE-2026-96652 exposure check

```
lab$  curl -s http://127.0.0.1:32400/identity | grep -o 'version="[^"]*"'
version="1.0"
version="1.43.2.10687-563d026ea"

lab$  curl -s http://127.0.0.1:32401/identity | grep -o 'version="[^"]*"'
version="1.0"
version="1.43.3.10861-07dfddaeb"

lab$  ss -ltn | grep 3240
LISTEN 0      4096       127.0.0.1:32400      0.0.0.0:*
LISTEN 0      4096       127.0.0.1:32401      0.0.0.0:*

lab$  dpkg-query -W plexmediaserver
dpkg-query: no packages found matching plexmediaserver

lab$  rpm -q plexmediaserver
package plexmediaserver is not installed

lab$  docker ps --format '{{.Names}} {{.Image}}' | grep -i plex
plexlab-fixed plexinc/pms-docker:1.43.3.10861-07dfddaeb
plexlab-vuln plexinc/pms-docker:1.43.2.10687-563d026ea
```

The CVE-2026-96654 run added the vendor's indicator hunt to the exposure check: a `find` for `.so` or `.dll` files under any `Plex Media Server/Codecs` path newer than `/etc/hostname`, and a process search for `myawesomeproxy`, `mylovelyminer` or `x12345`. Both returned nothing on the lab host (**Demonstrated**, CVE-2026-96654/03-exposure.txt).

CVE-2026-96654 exposure check and IOC hunt

```
lab$  dpkg-query -W -f='${Package} ${Version}\n' plexmediaserver 2>/dev/null || rpm -q plexmediaserver
package plexmediaserver is not installed

lab$  curl -s http://127.0.0.1:32400/identity | grep -o 'version="[^"]*"'
version="1.0"
version="1.43.3.10828-00f62d37d"

lab$  docker ps --format '{{.Names}} {{.Image}}' | grep -i plex
plex-fixed plexinc/pms-docker:1.43.3.10861-07dfddaeb
plex-vuln plexinc/pms-docker:1.43.3.10828-00f62d37d

lab$  ss -ltnp | grep 32400
LISTEN 0      4096       127.0.0.1:32400      0.0.0.0:*

lab$  timeout 300 find / -path '*Plex Media Server/Codecs*' \( -name '*.so' -o -name '*.dll' \) -newer /etc/hostname

lab$  ps -eo user,pid,cmd | grep -E 'myawesomeproxy|mylovelyminer|x12345' | grep -v grep
```

The CVE-2026-96655 run tried the native-install paths as well. On a Docker-only host, the log under `/var/lib/plexmediaserver` and the Codecs folder there do not exist, so those checks fail with `No such file or directory`; the Windows registry check was not run on the Linux host (**Demonstrated**, CVE-2026-96655/03-exposure.txt).

CVE-2026-96655 exposure check

```
### CVE-2026-96655 exposure_check (run on the lab host)  2026-11-04T05:46:58Z
# Docker hosts: Plex containers and image tags (below 1.43.3.10861 = vulnerable)
lab$  docker ps -a --format '{{.Names}} {{.Image}}' | grep -i plex
plex-fixed plexinc/pms-docker:1.43.3.10861-07dfddaeb
plex-vuln plexinc/pms-docker:1.43.3.10828-00f62d37d

# Debian/Ubuntu native package (host)
lab$  dpkg-query -W plexmediaserver
dpkg-query: no packages found matching plexmediaserver

# RPM native package (host)
lab$  rpm -q plexmediaserver
package plexmediaserver is not installed

# Local identity endpoint
lab$  curl -s http://127.0.0.1:32400/identity
<?xml version="1.0" encoding="UTF-8"?>
<MediaContainer size="0" apiVersion="1.2.2" claimed="0" machineIdentifier="02efc5139b2b88f063705d6684f765516669b5e5"
</MediaContainer>

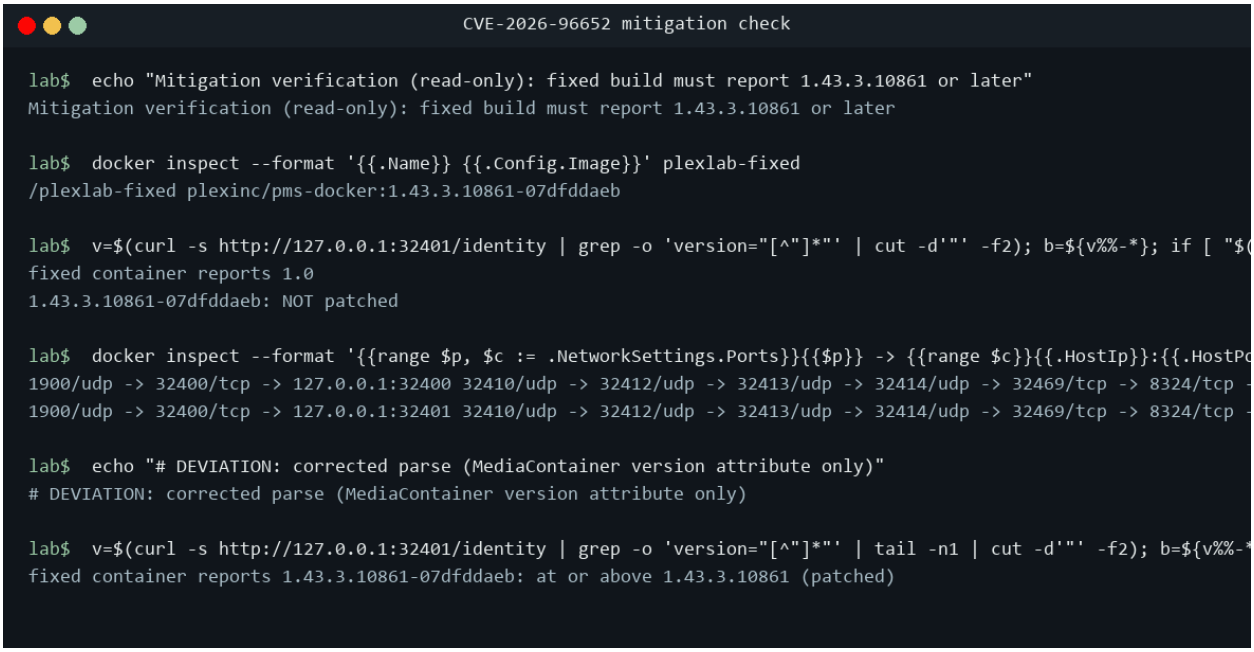
# Linux native install log banner
lab$  grep -m1 -i 'Plex Media Server v' '/var/lib/plexmediaserver/Library/Application Support/Plex Media Server/Logs
grep: /var/lib/plexmediaserver/Library/Application Support/Plex Media Server/Logs/Plex Media Server.log: No such fil

# Windows registry check: not applicable on this Linux host, not run
# Vendor IOC sweep, Linux native Codecs path
lab$  find '/var/lib/plexmediaserver/Library/Application Support/Plex Media Server/Codecs' -type f \( -name '*.so' -
find: ‘/var/lib/plexmediaserver/Library/Application Support/Plex Media Server/Codecs’: No such file or directory

# Is 32400 listening on all interfaces?
lab$  ss -ltnp | grep 32400
LISTEN 0      4096       127.0.0.1:32400      0.0.0.0:*
```

The fix, verified

Mitigation was verified read-only (**Demonstrated**, CVE-2026-96652/04-mitigation.txt, CVE-2026-96655/04-mitigation.txt, CVE-2026-96656/04-mitigation.txt). The fixed container reported 1.43.3.10861-07dfddaeb, at or above the threshold, its package agreed, and `docker port` and `docker inspect` showed the published ports bound to loopback only. The fixed server's preferences carried no `TranscoderH264Options` value. The vendor workaround, turning Remote Access off, was not tested, because the servers were unclaimed and Remote Access needs a server signed in to a Plex account [23].



The screenshot keeps the defective first check, because it is the clearest picture of the parsing trap: the first verdict is wrong, and the corrected one below it is right.



Cleanup, verified

Cleanup was verified for the CVE-2026-96652, -96654 and -96656 runs: containers, volumes and images removed, the lab ports clear, `docker ps -a` empty, and each work directory gone (**Demonstrated**, 05-cleanup.txt in each directory).

CVE-2026-96652 cleanup

```
lab$  docker rm -f plexlab-vuln plexlab-fixed
plexlab-vuln
plexlab-fixed

lab$  docker volume rm plexlab-vuln-config plexlab-fixed-config
plexlab-vuln-config
plexlab-fixed-config

lab$  docker rmi plexinc/pms-docker:1.43.2.10687-563d026ea plexinc/pms-docker:1.43.3.10861-07dfddaeb
Untagged: plexinc/pms-docker:1.43.2.10687-563d026ea
Untagged: plexinc/pms-docker@sha256:c37106c57fed7a6624f5dee5a3ce460ff011f09a2aa7f4ee9e8dbbd08ae1b87e
Deleted: sha256:5b74fc8790439cff70288872764c860b95195e6ff6e42da6e5be56cf68fb431d
Deleted: sha256:45b89b8dc70ea97a231b43633c11afdc8806d0fd8785992e9629c55db8579389
Deleted: sha256:e0381faf422ed3ccdbee920f3a472b5e25cbca9498cf90bdca3bc867a3c272d0
Deleted: sha256:154a8beb64b1376e621cd25eb942b3930ed706de41cdd4ce49188e317ac4b6ad
Deleted: sha256:712a15c4abedd99bc90485b3d161022b51ab561ec82d2b9257b2fd5fcc0a5897
Deleted: sha256:2528994af24e50df5258d6b6eea9a9fdabe6fc2665b44cce662fe56f5eabcd5f
Deleted: sha256:538812a4b9bd45adaac2b5e5b967daa6999aa44eb110aa32ae7c69702b906475
Untagged: plexinc/pms-docker:1.43.3.10861-07dfddaeb
Untagged: plexinc/pms-docker@sha256:5bc1d13f48da6366f46aaf2a3ce1a6292897eadc1f8efcbbd7321d30e94f2ed4
Deleted: sha256:29dffcb0de3ba8c2f12378c0b20a3907ccea41653b1b12cde008d5f8a5946aa9
Deleted: sha256:9c423918622b9724714191007beb78d77da44d961a8371fd665a06676732d14f
Deleted: sha256:4400f3b31f283b8bc8bb3896bfe67fafaef288c6abc09fb91f3f017c4d0cb83e
Deleted: sha256:7d7b6f9cf36d1ae499daf56306c038c474d434d20e0220d44a00d47a62cb8a8e
Deleted: sha256:294945b3d6eabb41a07fbf87e3bbfe26f056afc8d6a0d67c0fcb898362f3f422
Deleted: sha256:b76f664fb9e62bd7c412e9725ff09c534d8337c220154be365f2107897d1e228
Deleted: sha256:42724e448bf499ec7d4b3c21d6cc68fe665ef677ed393c3dbb5357394e89ff91

lab$  ss -ltn | grep -E '3240[0-2]' || echo 'clean'
clean

lab$  docker ps -a
CONTAINER ID   IMAGE     COMMAND   CREATED   STATUS    PORTS     NAMES

lab$  docker volume ls | grep plexlab || echo 'no plexlab volumes'
no plexlab volumes

lab$  docker images | grep pms-docker || echo 'no pms-docker images'
no pms-docker images

lab$  rm -rf /tmp/lab/CVE-2026-96652/ ; test -e /tmp/lab/CVE-2026-96652 && echo STILL-THERE || echo removed
removed
```

The CVE-2026-96655 run was not fully clean. Its containers, images and listeners were removed, but removing the bind-mounted config folders under `/tmp/lab` failed with `Permission denied`, leaving two empty directory skeletons owned by root that the unprivileged lab user could not remove; `/tmp` on the lab host is a tmpfs that clears on reboot (**Demonstrated**, CVE-2026-96655/05-cleanup.txt and plan.json). The other runs mounted no host folder: the CVE-2026-96652 run used named volumes and removed them with `docker volume rm`, and the -96654 and -96656 runs removed their containers with `docker rm -f -v` (**Demonstrated**, 05-cleanup.txt in each directory). For anyone repeating the lab, avoiding a bind mount avoids the leftover (**Inferred**).

CVE-2026-96655 cleanup

```
### CVE-2026-96655 cleanup  2026-11-04T05:47:03Z
lab$  docker rm -f plex-vuln plex-fixed
plex-vuln
plex-fixed

lab$  docker rmi plexinc/pms-docker:1.43.3.10828-00f62d37d plexinc/pms-docker:1.43.3.10861-07dfddaeb
Untagged: plexinc/pms-docker:1.43.3.10828-00f62d37d
Untagged: plexinc/pms-docker@sha256:a2b03d75aa16f422488c692935cab476d966b75f2af3c93bb6d910c6051906f5
Deleted: sha256:96f1f4f7569d2d244e94049f49d7fd47a968f174449c995254294fcb766748d1
Deleted: sha256:ef795b7da18855436725bc5ce6fdcef008539d656b2620c7ea6cc637d4805e34
Deleted: sha256:53d8ad1ba50d0f21bfc73b42fdd9b34231831444d09c058e728371fc9d20b404
Deleted: sha256:bdfc4f198ebf79cc01d5448079f441a3273ddc09c565bbe6d8624b5c1a6c9ee5
Deleted: sha256:5058e1cae73a43e30cfa06a7834b39d9082cf4598c4d4a9b187f0ad0d3a2b509
Deleted: sha256:53d128d5d5241c0d87ff0e7571e754f813ccd9e697c41261a0a69ad653cd25ad
Deleted: sha256:f103cd120fdd6cbc7f3d0e1d5bfb3e16290c32ead7b822d15c34460ecdf64b29
Untagged: plexinc/pms-docker:1.43.3.10861-07dfddaeb
Untagged: plexinc/pms-docker@sha256:5bc1d13f48da6366f46aaf2a3ce1a6292897eadc1f8efcbbd7321d30e94f2ed4
Deleted: sha256:29dffcb0de3ba8c2f12378c0b20a3907ccea41653b1b12cde008d5f8a5946aa9
Deleted: sha256:9c423918622b9724714191007beb78d77da44d961a8371fd665a06676732d14f
Deleted: sha256:4400f3b31f283b8bc8bb3896bfe67fafaef288c6abc09fb91f3f017c4d0cb83e
Deleted: sha256:7d7b6f9cf36d1ae499daf56306c038c474d434d20e0220d44a00d47a62cb8a8e
Deleted: sha256:294945b3d6eabb41a07fbf87e3bbfe26f056afc8d6a0d67c0fcb898362f3f422
Deleted: sha256:b76f664fb9e62bd7c412e9725ff09c534d8337c220154be365f2107897d1e228
Deleted: sha256:42724e448bf499ec7d4b3c21d6cc68fe665ef677ed393c3dbb5357394e89ff91

lab$  rm -rf /tmp/lab/CVE-2026-96655/plexlab && echo plexlab-removed
rm: cannot remove '/tmp/lab/CVE-2026-96655/plexlab/fixed-config/Library/Application Support/Plex Media Server': Perm
rm: cannot remove '/tmp/lab/CVE-2026-96655/plexlab/vuln-config/Library/Application Support/Plex Media Server': Permi

lab$  ss -ltn | grep -E '3240[01]' || echo 'ports clear'
ports clear

lab$  docker ps -a --format '{{.Names}} {{.Image}}'; echo 'docker ps -a done (no lines above = nothing left)'
docker ps -a done (no lines above = nothing left)

lab$  docker images --format '{{.Repository}}:{{.Tag}}' | grep -i plex || echo 'no plex images'
no plex images

lab$  docker network ls --format '{{.Name}}'
bridge
host
none

lab$  rm -rf /tmp/lab/CVE-2026-96655/
rm: cannot remove '/tmp/lab/CVE-2026-96655/plexlab/fixed-config/Library/Application Support/Plex Media Server': Perm
rm: cannot remove '/tmp/lab/CVE-2026-96655/plexlab/vuln-config/Library/Application Support/Plex Media Server': Permi

lab$  find /tmp/lab/CVE-2026-96655 -printf "%u %s %p
"
kali 60 /tmp/lab/CVE-2026-96655
kali 80 /tmp/lab/CVE-2026-96655/plexlab
kali 60 /tmp/lab/CVE-2026-96655/plexlab/fixed-config
root 60 /tmp/lab/CVE-2026-96655/plexlab/fixed-config/Library
root 60 /tmp/lab/CVE-2026-96655/plexlab/fixed-config/Library/Application Support
kali 40 /tmp/lab/CVE-2026-96655/plexlab/fixed-config/Library/Application Support/Plex Media Server
kali 60 /tmp/lab/CVE-2026-96655/plexlab/vuln-config
root 60 /tmp/lab/CVE-2026-96655/plexlab/vuln-config/Library
root 60 /tmp/lab/CVE-2026-96655/plexlab/vuln-config/Library/Application Support
kali 40 /tmp/lab/CVE-2026-96655/plexlab/vuln-config/Library/Application Support/Plex Media Server

lab$  docker ps -a --format {{.Names}}
docker ps -a done (no lines above = nothing left)
```

What the lab does and does not show

It shows, on one host on one date, that the official images report their build number through three separate observables (the `/identity` response, the package database and the server log), that a version gate built on the package or on the MediaContainer attribute tells 1.43.3.10828 from 1.43.3.10861, that a host package check misses a containerized server, and that a fresh server has an empty Codecs folder and no transcoder override (**Demonstrated**) [38] [39] [40] [41]. It does not show the chain: no exploit step ran, and the chain mechanics rest on the researcher and the vendor [12] [9]. It does not show whether a claimed server answers `/identity` without a token, which was not checked, and it does not test the Remote Access workaround (**Inferred** limits).

Part 5: find it and fix it on real hosts

Read the version, by platform

Platform	Where the data lives	Read the version	Fix	Source
Any	Plex Web	Settings, General	Update to 1.43.3.10861 or later	[9]
Any, over the network	TCP 32400	`curl -s http://HOST:32400/identity`, then read the MediaContainer `version` attribute, never the XML declaration; tested only on unclaimed servers	as above	[38] (**Demonstrated**); claimed servers not checked
Debian, Ubuntu	`/var/lib/plexmediaserver/Library/Application Support/Plex Media Server/`	`dpkg-query -W plexmediaserver`	From the Plex repository, `sudo apt install -y plexmediaserver`; or `sudo dpkg -i` on the downloaded `.deb`	[18] [21] [9]; check [38]
Fedora, CentOS	same data path	`rpm -q plexmediaserver`	`sudo dnf install -y plexmediaserver` from the repository (rpm 4.16 or later), or `sudo dnf install` on the downloaded `.rpm`	[18] [21] [9]
Linux repository users	`/etc/apt/sources.list.d/plex*`, `/etc/yum.repos.d/plex*`		The repositories changed starting with 1.43.0: remove the old repository files and add `repo.plex.tv`, signed with `PlexSign.v2.key`. A host still pointing at the old repository would not receive the fixed build (**Inferred**)	[21]
Snap	`/var/snap/plexmediaserver/common/Library/Application Support`	Plex Web	Not documented in the sources opened	[18]
Synology DSM 7	`/volume1/PlexMediaServer/AppData/Plex Media Server`	Plex Web	Manual package install on the NAS	[18] [9]
Docker	`/config/Library/Application Support/Plex Media Server` inside the container	Image tag from `docker ps`; `docker exec <container> dpkg-query -W plexmediaserver`; the banner in `Plex Media Server.log`	Move to a pinned tag at 1.43.3.10861 or later, per the pms-docker README. The `public` and `beta` tags install the latest server at start and update on restart	[22] [9]; checks [38] [40]
Windows	`%LOCALAPPDATA%\Plex Media Server`; preferences in the registry at `HKEY_CURRENT_USER\Software\Plex, Inc.\Plex Media Server`	Plex Web	Automatic updates or the Downloads page	[18] [19] [9]

Platform	Where the data lives	Read the version	Fix	Source
macOS	`~/Library/Application Support/Plex Media Server/`; preferences in `~/Library/Preferences/com.plexapp.plexmediaserver.plist`	Plex Web	Automatic updates or the Downloads page	[18] [19] [9]
NVIDIA Shield		Plex Web	Google Play updates	[9]

The Codecs folder and, on Linux, `Preferences.xml` live in the data directory [18]. On Windows and macOS, server preferences live in the registry key or the plist, so the `TranscoderH264Options` check belongs there, not in a file (**Inferred** from [19]). Logs are in `%LOCALAPPDATA%\Plex Media Server\Logs` on Windows, `~/Library/Logs/Plex Media Server/` on macOS, and a `Logs` folder in the data directory on Linux and NAS, usually owned by `plex:plex`; they can also be downloaded from the server's troubleshooting settings [20].

If the server was exposed

Plex's guidance for any server older than 1.43.3.10861 that was reachable from the internet is to assume it may be compromised (**Confirmed**: Plex) [9]:

1. Rebuild from a clean install rather than reusing the old data directory.
2. At minimum, delete the contents of the Codecs folder and check the server preferences for transcoder options you did not set.
3. Sign out of all devices and change the Plex password.
4. Treat anything the server's service account could reach as exposed.

KEV's forensic-triage flag on CVE-2026-96656 points the same way: on an exposed server, patching closes the door but does not clear what came through it [7].

If you cannot update today

Turn Remote Access off if you do not need it (Settings, Remote Access in the vendor's advisory; Settings, Server, Remote Access in the support article), and do not forward port 32400 directly [9] [23]. Remote Access maps an external port to the internal 32400 through UPnP, NAT-PMP or a manual forward, so check the router as well as the server [23]. The pms-docker README warns that `ALLOWED_NETWORKS` allows access without authorization, so keep it narrow [22]. None of this was tested in the lab.

Part 6: detection

What to look for	Where	Basis	Grade
Any server, image or package below 1.43.3.10861	`/identity`, image tags, package databases	Version line [5]; method [38]	Confirmed; Demonstrated
Plex images on hosts with no Plex package	`docker ps`, `docker images` on every container host	[38]	Demonstrated
`/system/agents/*` requests labelled `(Loopback)` shortly after a `/player/timeline` request from a WAN or Subnet client	`Plex Media Server.log`	Locality labels [38]; chain [12]	Inferred
`/player/timeline` requests whose `protocol=` value is a full URL	`Plex Media Server.log`, reverse proxy logs	[1] [12]	Inferred
`/video/:/transcode/universal` requests whose `path=` points at an external or loopback URL	as above	[3] [12]	Inferred
Writes to `/:/prefs` touching `TranscoderH264Options`	as above	[4] [10] [12]	Inferred
A `TranscoderH264Options` value you did not set	`Preferences.xml`, registry or plist	[9] [19]; clean baseline [41]	Confirmed; Demonstrated
New `.so` or `.dll` files in Codecs	File-integrity monitoring on the data directory	[9]; clean baseline [39]	Confirmed; Demonstrated
Processes started by Plex named `myawesomeproxy`, `mylovelyminer` or `x12345`, or an XMRig miner	Process telemetry, children of the `plex` user	[9] [14]	Confirmed
Outbound connections to `proxystream.st`; outbound requests from the Plex process to names that begin with `127.0.0.1` but resolve elsewhere, such as `sslip.io` names	DNS and egress logs	[9] [12] [14]	Confirmed (vendor IOC); Inferred (rule)
Sustained high CPU while nothing plays	Host monitoring	[9]	Confirmed
The honeypot's source addresses and `Python-urllib/3.10` user agent	Firewall and web logs	One honeypot only [14]	Weak signal

With Docker bridge networking, requests from the host side appear in the log as coming from the Docker gateway address, `172.17.0.1` in the lab, labelled `(Subnet)` [38] [22]. Shipping the log to a SIEM is easier with syslog output, which Plex enables with `PLEX_MEDIA_SERVER_USE_SYSLOG=true` (on systemd, in an `override.conf` for the service) [19]. The request-pattern rules in the table are this study's reading of the record, not tested signatures (**Inferred**); the packet captures the honeypot operator recorded in their own lab test of the public chain are a starting point for testing them [14].

Part 7: the vulnerability-management view

- **Score each CVE, but triage the chain.** A program that sorts by individual CVSS would see three Mediums and one High that needs admin rights, and might schedule them for the next routine cycle. The chain is unauthenticated remote code execution, and it was exploited within about a day of the write-up [12] [14]. KEV's note that each entry chains with the other three is the signal to treat them as one item [7].
- **The fix date and the disclosure date are different clocks.** The fixed build shipped on 4 August, and exploitation started on 17 October [10] [14]. Owners who reached 1.43.3.10861 before 16 October were patched before the public write-up and PoC; owners who read "1.43.3 or newer" and stopped at 1.43.3.10828 were not (**Inferred**) [9] [10].
- **Consumer software on business networks.** Plex Media Server is home media software, and it runs on NAS devices, desktops and containers that a corporate asset inventory may never list. KEV's due dates are set under a CISA directive, but the inventory gap applies to anyone whose staff run home servers on networks they also use for work, or who host Plex on shared infrastructure (**Inferred**).
- **Version checks are only as good as the parser.** The lab's own parse defect is a small version of a common scanner failure: read the wrong attribute and a fixed host is flagged, or a vulnerable one is cleared [38] [39]. A gate built on the package database, or on the single attribute that carries the build number, avoids it.

Overstated and understated

- **Overstated:** the honeypot's source addresses and user agent as a detection basis, because they come from one honeypot and the operator says so (**Confirmed** as one operator's observation [14]); and the link between `proxystream.st` and the AISURU botnet, which rests on one press report citing a vendor (**Reported** [17]). No opened source names a group, and KEV lists ransomware use as Unknown (**Confirmed** [7]).
- **Understated:** the severity of the chain, which no CVSS record scores while each CVE alone scores Medium or High (**Confirmed** [1] [2] [3] [4]; the chain rating is the researcher's [12]); the affected range, which the advisory title puts at "v1.43.2 and earlier" although 1.43.3.10828 is vulnerable (**Inferred** from [5] [6] [9]); and exposure on hosts where Plex runs only in containers, which a package-based inventory misses (**Demonstrated** [38]).

Part 8: MITRE mappings

Each technique below is this study's binding of the record's attack path to the technique's definition, with the basis stated; every id was checked on the live ATT&CK page (v20.0) and against the library's generated pages [24] to [30] [37].

ATT&CK Enterprise techniques

Tactic names follow ATT&CK v20.0, where the former Defense Evasion tactic is split into Stealth and Defense Impairment.

ATT&CK id	Name	Tactic (v20)	Dated event or report	Basis	Source
T1190	Exploit Public-Facing Application	Initial Access	Plex's update (2026-10-19); honeypot exploitation (2026-10-17)	Plex: the chained issues let an unauthenticated remote attacker run code (Confirmed)	[9] [14] [24]
T1528	Steal Application Access Token	Credential Access	Plex's CVE table for -96655 (2026-10-19); researcher stage 3 (2026-10-16)	Theft of the server owner's token (Confirmed)	[9] [12] [25]
T1129	Shared Modules	Execution	NVD record for -96656 (2026-09-23); researcher stage 5 (2026-10-16)	Every `.so` in Codecs is loaded and run at startup (Confirmed)	[4] [12] [26]
T1105	Ingress Tool Transfer	Command and Control	Researcher stage 4 (2026-10-16); honeypot payload download (2026-10-17)	The transcoder fetches an attacker-hosted file; miner and binary downloaded in the wild (Confirmed)	[12] [14] [27]
T1496.001	Resource Hijacking: Compute Hijacking	Impact	Plex's update (2026-10-19); honeypot XMRig (2026-10-17)	Cryptocurrency miners on compromised servers (Confirmed)	[9] [14] [28]
T1496.002	Resource Hijacking: Bandwidth Hijacking	Impact	Plex's update (2026-10-19); honeypot `myawesomeproxy` (2026-10-17)	Proxy software routing other people's traffic through the victim (Confirmed)	[9] [14] [28]
T1059.004	Command and Scripting Interpreter: Unix Shell	Execution	Researcher write-up (2026-10-16); The Hacker News report (2026-10-19)	The public PoC opens a reverse shell [12]; The Hacker News reports a shell script fetching the miner x12345 in the wild (Reported) [17]	[12] [17] [30]

Two techniques used by earlier lab plans are left out. T1574 Hijack Execution Flow (tactics Stealth and Execution on the live page) fits the `.so` load less well than T1129, because nothing is hijacked: the server loads every library in the folder by design [26]. T1090.001 Proxy: Internal Proxy is a weak fit for the loopback SSRF pivot, which is a forged request, not a relay (**Inferred**). T1595.002 Active Scanning: Vulnerability Scanning is also left out: the honeypot operator reports mostly generic scanning and exploitation attempts, not scanning for these CVEs [14] [29] (**Inferred**). ATT&CK for ICS and ATT&CK for Mobile do not apply.

Group, software and campaign objects

None is bound. No source opened attributes the exploitation to a named actor, and a search of the library for Plex returned no relevant group, software or campaign page [37]. The ATT&CK site search was not checked.

CWE and CAPEC

Id	Name	Where it appears	Source
CWE-918	Server-Side Request Forgery (SSRF)	CVE-2026-96652 and CVE-2026-96655 in NVD, KEV and the CISA advisory	[1] [3] [6] [7] [31]
CWE-84	Improper Neutralization of Encoded URI Schemes in a Web Page	CVE-2026-96654, same sources	[2] [6] [7] [32]
CWE-73	External Control of File Name or Path	CVE-2026-96656, same sources	[4] [6] [7] [33]
CAPEC-664	Server Side Request Forgery	The CAPEC that the CWE-918 page lists; the library page links CWE-918	[31] [34] [37]
CAPEC-76	Manipulating Web Input to File System Calls	Linked to CWE-73 on the library page; its binding to CVE-2026-96656 is Inferred	[35] [37]

The CWE-84 page lists no related CAPEC, so none is bound for CVE-2026-96654 [32]. The library has no per-id CWE pages; see the CWE Reference.

D3FEND countermeasures

Each id was confirmed through the D3FEND API, and each has a page in the library [36] [37]:

Countermeasure	Id	Why it applies here	Library tactic or mapped technique
Software Update	D3-SU	The vendor fix: 1.43.3.10861 or later	Harden
Asset Vulnerability Enumeration	D3-AVE	Finding every server, image and package below the fixed line, containers included	Model
Disable Remote Access	D3-DRA	The vendor workaround: Remote Access off	Harden
Inbound Traffic Filtering	D3-ITF	No direct forward of 32400	Mapped to T1190
Outbound Traffic Filtering	D3-OTF	Blocking the transcoder's fetches and the miners' and proxies' callbacks	Mapped to T1105
File Integrity Monitoring	D3-FIM	Codecs and the server preferences, against the clean baseline	Detect
Process Spawn Analysis	D3-PSA	Unknown processes started by Plex	Detect
Credential Rotation	D3-CRO	Change the Plex password	Mapped to T1528
Credential Revocation	D3-CR	Sign out of all devices	Mapped to T1528
URL Analysis	D3-UA	URL values in `protocol=` and `path=` parameters	Inferred fit
Application Configuration Hardening	D3-ACH	Clearing transcoder options you did not set	Inferred fit

The last column gives the library page's D3FEND tactic, or the ATT&CK technique the library maps the countermeasure to; the "why it applies" column is this study's reading (**Inferred**). See the D3FEND Reference.

Navigator layer

navigator/library-layers/plex-media-server-2026.json carries the seven technique entries above (ATT&CK v20, domain `enterprise-attack`), listed with the library's other curated layers on the Navigator layers page. Score 100 marks bindings a primary source supports for these CVEs (T1190, T1528, T1129, T1105, T1496.001, T1496.002); score 60 marks bindings that rest on a single press report (T1059.004). Scores mean evidence basis, not frequency or severity. Each entry's comment names the source numbers in this study.

MITRE ATT&CK, CWE, CAPEC and D3FEND content is used under the terms recorded in THIRD_PARTY_NOTICES.md.

Cross-cutting themes

- **Chains beat scores.** Four individually moderate CVEs became an unauthenticated remote code execution, the same lesson that runs through PHP2Shell and the October 2026 Attack Wave, which records the Plex KEV additions in the same week, and through Log4Shell, where a logging feature became a remote fetch (**Inferred**) [7] [12].
- **Loopback is not a trust boundary.** The chain's pivot is a server that trusts its own loopback origin and a framework that attaches a secret to any URL that starts with `http://127.0.0.1` [12]. Any service that treats "came from localhost" as "came from me" can be walked into the same shape by a request-forgery bug (**Inferred**).
- **A plugin folder is a code path.** The final stage works because the transcoder loads every library in a writable folder with no signature check [4] [12]. A folder an application loads code from deserves the monitoring and permissions of the application binary itself (**Inferred**).
- **Advisory wording is part of the fix.** A title that says "v1.43.2 and earlier" and a first post that says "1.43.3 or newer" left room to stop at the last vulnerable build, and NVD's release-notes link pointed at it [9] [10]. Defenders should read the version boundary from the CVE record, not the headline (**Inferred**).
- **Machine-assisted research is in the record.** The researcher describes a workflow that used language models heavily for recon, hunting, verification and chaining, with the judgement calls kept human [12]. The direction matches the AI Threats 2026 study and the CVE-2026-98432 study (**Inferred**).
- **Lab plans are hypotheses.** The plans expected a version in `docker logs` and a working version parser; the runs found neither, and writing the expectation down first is how both corrections reached this study [38] [41].

Sources

Sources 1 to 37 were opened on 4 November 2026; sources 38 to 41 are the lab capture sets, recorded on 4 November 2026 UTC.

#	Source	URL	Opened	Grade
1	NVD record CVE-2026-96652 (API 2.0; published 2026-09-23; CISA ADP SSVC)	https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-96652	2026-11-04	Confirmed
2	NVD record CVE-2026-96654	https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-96654	2026-11-04	Confirmed

#	Source	URL	Opened	Grade
3	NVD record CVE-2026-96655	https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-96655	2026-11-04	Confirmed
4	NVD record CVE-2026-96656	https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-96656	2026-11-04	Confirmed
5	CVE records CVE-2026-96652, -96654, -96655 and -96656 (CNA CISA, assigner `cisa-cg`), each at the same API path	https://cveawg.mitre.org/api/cve/CVE-2026-96652	2026-11-04	Confirmed
6	CISA CSAF advisory VA-26-266-01 (initial release 2026-09-23)	https://raw.githubusercontent.com/cisagov/CSAF/develop/csaf_files/IT/white/2026/va-26-266-01.json	2026-11-04	Confirmed
7	CISA Known Exploited Vulnerabilities feed (catalog 2026.11.03)	https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-04	Confirmed
8	GitHub advisories GHSA-5p7w-r379-3c2m, GHSA-3j7c-jr86-m5jq, GHSA-9x88-w2p7-56vh and GHSA-2g2v-9wf5-6m3g	https://github.com/advisories/GHSA-2g2v-9wf5-6m3g	2026-11-04	Confirmed
9	Plex, "Important Security Update for Plex Media Server v1.43.2 and earlier" (post 1 of 2026-09-01; update of 2026-10-19, edited 2026-10-20)	https://forums.plex.tv/t/important-security-update-for-plex-media-server-v1-43-2-and-earlier/942319	2026-11-04	Confirmed
10	Plex Media Server release-notes thread (post 711 for 1.43.3.10828 of 2026-07-14; the 1.43.3.10861 Beta and general release posts of 2026-08-03 and 2026-08-04)	https://forums.plex.tv/t/plex-media-server/30447/711	2026-11-04	Confirmed
11	Docker Hub tag records for `plexinc/pms-docker` 1.43.2.10687-563d026ea, 1.43.3.10828-00f62d37d and 1.43.3.10861-07dfddaeb	https://hub.docker.com/v2/repositories/plexinc/pms-docker/tags/1.43.3.10861-07dfddaeb	2026-11-04	Confirmed
12	Zach Main, "Plex2Shell" (2026-10-16)	https://zmain.info/blog/plex2shell	2026-11-04	Confirmed (researcher primary)
13	PoC repository `code-zm/plex2shell` (GPL-3.0, created 2026-10-18); metadata and README CVE table only, recorded by name and not linked	`github.com/code-zm/plex2shell`	2026-11-04	Confirmed (metadata)
14	boredhackerblog, "Plex vulnerabilities being exploited in the wild to drop a cryptominer" (independent honeypot write-up, 2026-10-17, edited 2026-10-17 and 2026-10-18)	https://www.boredhackerblog.info/2026/10/plex-vulnerabilities-being-exploited-in.html	2026-11-04	Confirmed (first-hand, one honeypot)
15	SecurityWeek, Plex2Shell exploitation report (2026-10-19)	https://www.securityweek.com/plex2shell-exploit-chain-weaponized-against-plex-servers-hours-after-disclosure/	2026-11-04	Reported
16	BleepingComputer, CISA warning on Plex2Shell (2026-10-21)	https://www.bleepingcomputer.com/news/security/cisa-hackers-chain-plex-flaws-in-plex2shell-attacks-to-breach-servers/	2026-11-04	Reported

#	Source	URL	Opened	Grade
17	The Hacker News, Plex2Shell exploitation report (2026-10-19)	https://thehackernews.com/2026/10/hackers-exploit-plex2shell-flaws-to.html	2026-11-04	Reported
18	Plex support, "Where is the Plex Media Server data directory located?"	https://support.plex.tv/articles/202915258-where-is-the-plex-media-server-data-directory-located/	2026-11-04	Confirmed
19	Plex support, "Advanced, Hidden Server Settings"	https://support.plex.tv/articles/201105343-advanced-hidden-server-settings/	2026-11-04	Confirmed
20	Plex support, "Plex Media Server Logs" (served at this URL)	https://support.plex.tv/articles/200250417-plex-media-server/	2026-11-04	Confirmed
21	Plex support, "Enable repository updating for supported Linux server distributions"	https://support.plex.tv/articles/235974187-enable-repository-updating-for-supported-linux-server-distributions/	2026-11-04	Confirmed
22	`plexinc/pms-docker` README	https://github.com/plexinc/pms-docker/blob/master/README.md	2026-11-04	Confirmed
23	Plex support, "Remote Streaming (Setting Up Remote Access)"	https://support.plex.tv/articles/200289506-remote-access/	2026-11-04	Confirmed
24	MITRE ATT&CK T1190	https://attack.mitre.org/techniques/T1190/	2026-11-04	Confirmed
25	MITRE ATT&CK T1528	https://attack.mitre.org/techniques/T1528/	2026-11-04	Confirmed
26	MITRE ATT&CK T1129	https://attack.mitre.org/techniques/T1129/	2026-11-04	Confirmed
27	MITRE ATT&CK T1105	https://attack.mitre.org/techniques/T1105/	2026-11-04	Confirmed
28	MITRE ATT&CK T1496.001 and T1496.002	https://attack.mitre.org/techniques/T1496/002/	2026-11-04	Confirmed
29	MITRE ATT&CK T1595.002	https://attack.mitre.org/techniques/T1595/002/	2026-11-04	Confirmed
30	MITRE ATT&CK T1059.004	https://attack.mitre.org/techniques/T1059/004/	2026-11-04	Confirmed
31	CWE-918 Server-Side Request Forgery (SSRF) (CWE 5.0)	https://cwe.mitre.org/data/definitions/918.html	2026-11-04	Confirmed
32	CWE-84 Improper Neutralization of Encoded URI Schemes in a Web Page	https://cwe.mitre.org/data/definitions/84.html	2026-11-04	Confirmed
33	CWE-73 External Control of File Name or Path	https://cwe.mitre.org/data/definitions/73.html	2026-11-04	Confirmed
34	CAPEC-664 Server Side Request Forgery	https://capec.mitre.org/data/definitions/664.html	2026-11-04	Confirmed
35	CAPEC-76 Manipulating Web Input to File System Calls	https://capec.mitre.org/data/definitions/76.html	2026-11-04	Confirmed

#	Source	URL	Opened	Grade
36	MITRE D3FEND API, Software Update and the other countermeasures in the D3FEND table	https://d3fend.mitre.org/api/technique/d3f:SoftwareUpdate.json	2026-11-04	Confirmed
37	Library data on main: the `mitre/` tree (techniques, CAPEC and D3FEND pages) and a code search for Plex	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/mitre	2026-11-04	Confirmed
38	Lab captures for CVE-2026-96652: `plan.json`, `01-setup.txt`, `02-test.txt`, `03-exposure.txt`, `04-mitigation.txt`, `05-cleanup.txt`, and the embedded screenshots `01-setup.png`, `03-exposure.png`, `04-mitigation.png` and `05-cleanup.png`	not published	2026-11-04	Demonstrated
39	Lab captures for CVE-2026-96654: `plan.json`, `01-setup-attempt1.txt`, `01-setup.txt`, `02-test.txt`, `03-exposure.txt`, `04-mitigation.txt`, `05-cleanup.txt`, and the embedded screenshot `03-exposure.png`	not published	2026-11-04	Demonstrated
40	Lab captures for CVE-2026-96655: `plan.json`, `01-setup-attempt1-collision.txt`, `01-setup.txt`, `02-test.txt`, `03-exposure.txt`, `04-mitigation.txt`, `05-cleanup.txt`, and the embedded screenshots `03-exposure.png` and `05-cleanup.png`	not published	2026-11-04	Demonstrated
41	Lab captures for CVE-2026-96656: `plan.json`, `01-setup.txt`, `02-test.txt`, `03-exposure.txt`, `04-mitigation.txt`, `05-cleanup.txt`, and the embedded screenshot `04-mitigation.png`	not published	2026-11-04	Demonstrated

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Threat Actors, Malware Families, Notable Incidents: no actor or malware family is attributed to this exploitation
- Vulnerability Prioritization Reference, Vulnerability Management Reference, Triage a CVE
- Internet-Facing Services Reference, Container Security Reference, Homelab Setup

- Other lab-backed studies: Ghostcat, the Tomcat AJP file read in the lab; ProFTPD mod_copy; Magento and Adobe Commerce PolyShell; Node.js Brotli decoder, another version check that tells a vulnerable build from a fixed one; PHP 8.4.27, the interpreter flaws CISA calls php2shell; Collabora Built-in CODE Server in Nextcloud, another self-hosted server exploited before most owners had read an advisory
- Other vulnerability studies: PHP2Shell and the October 2026 attack wave, which records the Plex KEV additions in the same week; Log4Shell, where a logging feature became a remote fetch; the Linux TCP use-after-free, CVE-2026-98432; AI Threats 2026
- Techniques: T1190 Exploit Public-Facing Application, T1528 Steal Application Access Token, T1129 Shared Modules, T1105 Ingress Tool Transfer, T1496.001 Compute Hijacking, T1496.002 Bandwidth Hijacking, T1059.004 Unix Shell
- CAPEC: CAPEC-664 Server Side Request Forgery, CAPEC-76 Manipulating Web Input to File System Calls
- D3FEND: Software Update, Asset Vulnerability Enumeration, Disable Remote Access, File Integrity Monitoring, Process Spawn Analysis, Outbound Traffic Filtering, all countermeasures
- Navigator layers, including this study's layer, plex-media-server-2026.json
- All case studies